Bypassing access controls using email address parsing discrepancies

This lab is Expert level so if u want to solve it by your self u need to understand some concept before you try as portswigger recommanded such as [Splitting the Email Atom: Exploiting Parsers to Bypass Access Controls]

the second choise u have is to read this writeup and i will try to explain what we need to understand to solve this lab as easy as possible without a lot of chatter.

The core concept of this lab relies on a vulnerability known as **Parsing Discrepancies**. Simply put, this vulnerability occurs when two different systems (for instance, the website's validation parser that checks the email, and the mail transfer agent that delivers the message) interpret the exact same text string in entirely different ways.

To visualize it, imagine standing in front of a security guard (the website's validation check) who refuses to let you in unless your address ends with `ginandjuice.shop`. At the same time, you need the mail carrier (the email server) to deliver the activation link to your actual inbox at `exploit-server.net`.

The solution is to write your address in an "encoded" language or using an unusual encoding (such as UTF-7)(if u are solving the lab without knowing its UTF-7 u could try others mechanisim such as UTF-8 etc... .T he security guard does not understand this encoding, so he only reads the end of the string, `@ginandjuice.shop`, and lets you pass. Meanwhile, the mail carrier understands this encoding, translates it, reads your real address, ignores the fake suffix, and delivers the message to you.

How Does the Trick Work Technically?

The website uses a software validation library to verify email addresses that is different from the library responsible for actually sending the email. We take advantage of an older email encoding mechanism known as **Encoded-word**, which supports character sets like UTF-7.

In UTF-7 encoding:

- The `@` symbol is represented as: `&AEA-`
- The space character is represented as: `&ACA-`

Payload Structure:

We format the email address like this: `=?utf-7?q?attacker&AEA-[YOUR-EXPLOIT-SERVER-ID]&ACA-?=@ginandjuice.shop`

How Both Systems Interpret This String:

1. **The Security Guard (The website's validation parser):**

   It treats the entire string as plain text. It observes that the string ends with `@ginandjuice.shop`, assumes the user belongs to the administrative domain, and permits registration with administrative privileges.

2. **The Mail Carrier (The email delivery subsystem):**

   It detects the `=?utf-7?q?` header and immediately recognizes that the enclosed text is encoded in UTF-7, prompting it to decode the content.

   Once decoded, the server-side representation becomes:

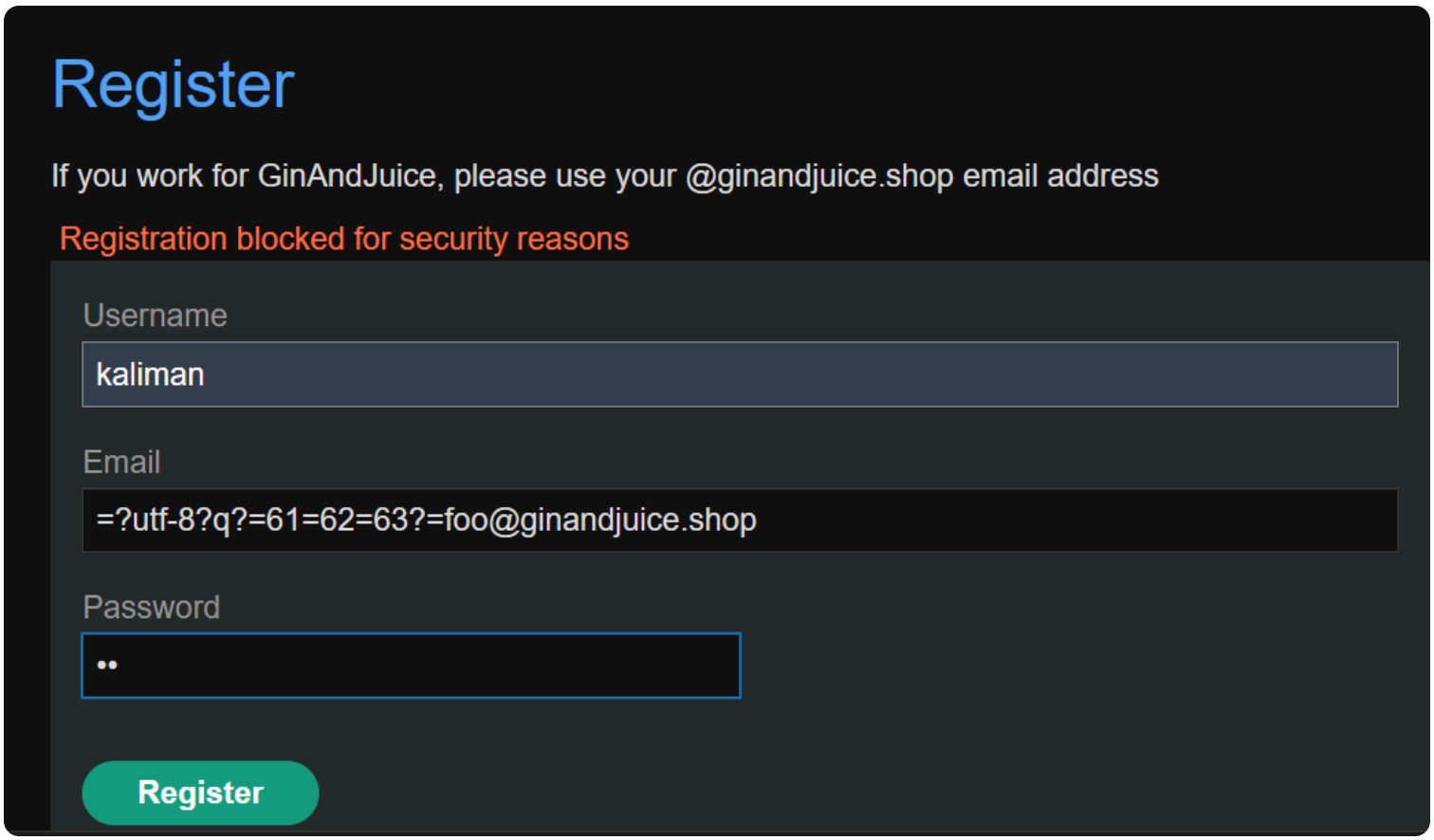
   `attacker@[YOUR-EXPLOIT-SERVER-ID] @ginandjuice.shop`

   Because of the trailing space (produced by `&ACA-`) preceding `@ginandjuice.shop`, the email routing engine considers the valid recipient address to have terminated at that boundary. It discards the remaining portion, resulting in the activation email being delivered directly to your exploit server.

ok now lets solve the lab after we understand whats going on :

first of all try to login with UTF-8 encoded value

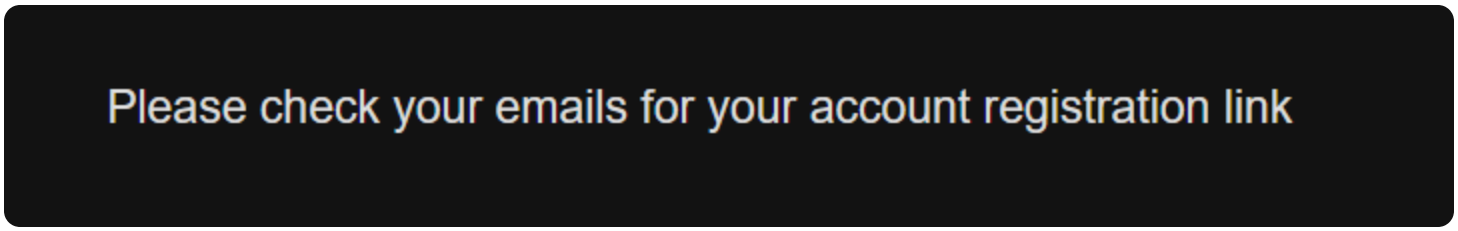
```
1   =?utf-8?q?=61=62=63?=foo@ginandjuice.shop
```



notice that u will get an error : "Registration blocked for security reasons."

so lets try UTF-7

```
=?utf-7?q?&AGEAYgBj-?=foo@ginandjuice.shop
```



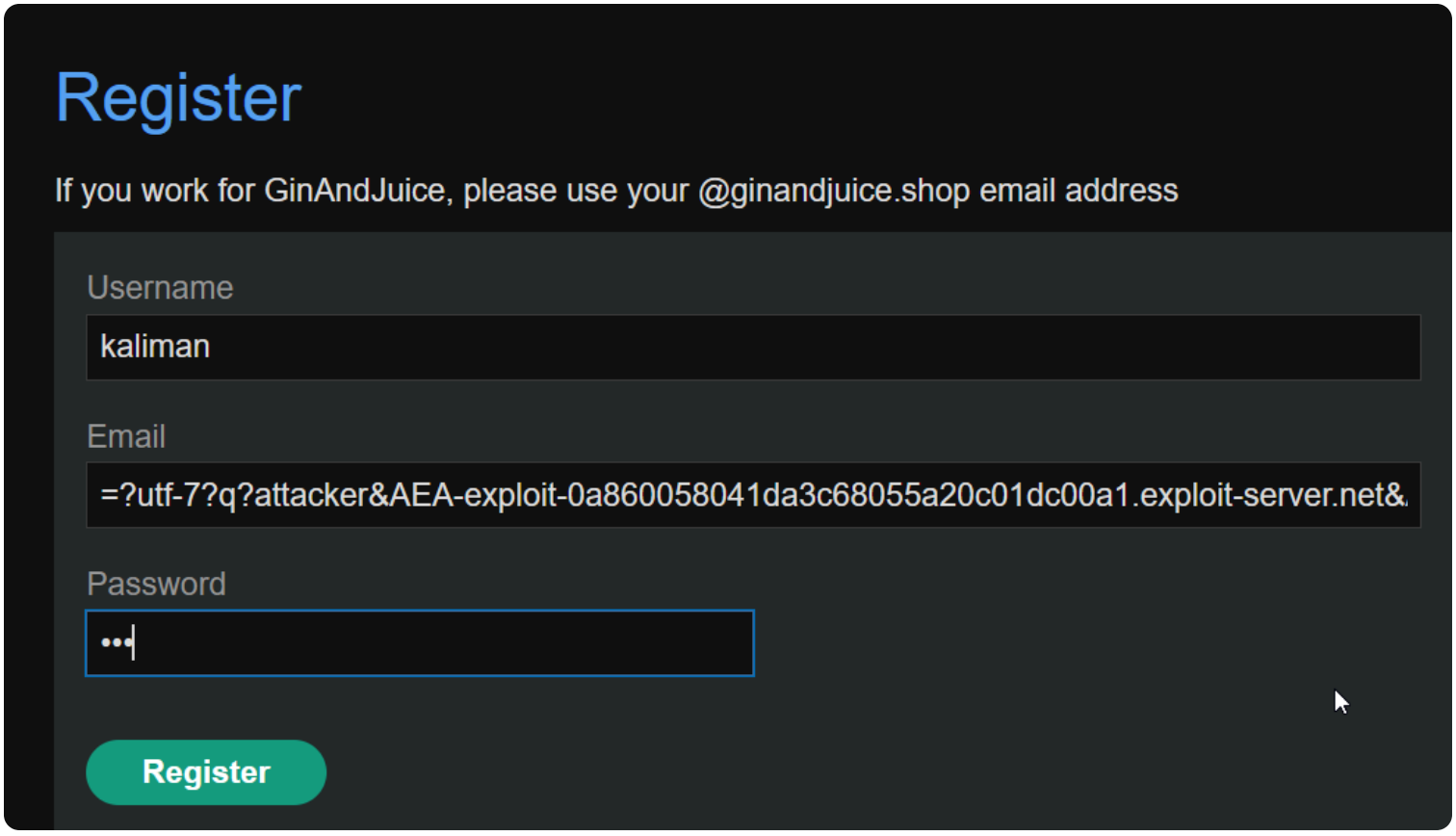
notice u processed successfuly.

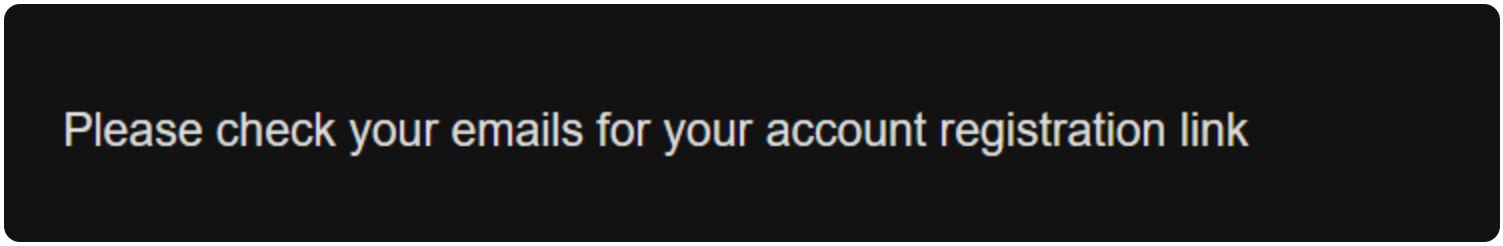
now we need to make code with UTF-7 which will skip the company email and send the message to our email with the space encode :

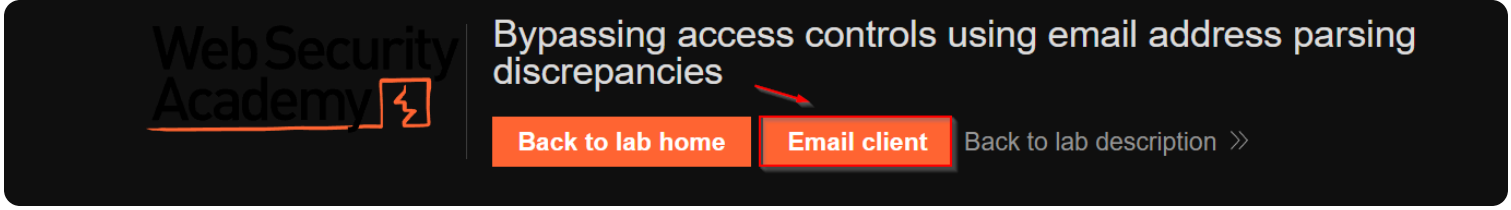
```
=?utf-7?q?attacker&AEA-[YOUR-EXPLOIT-SERVER_ID]&ACA-?=@ginandjuice.shop
```

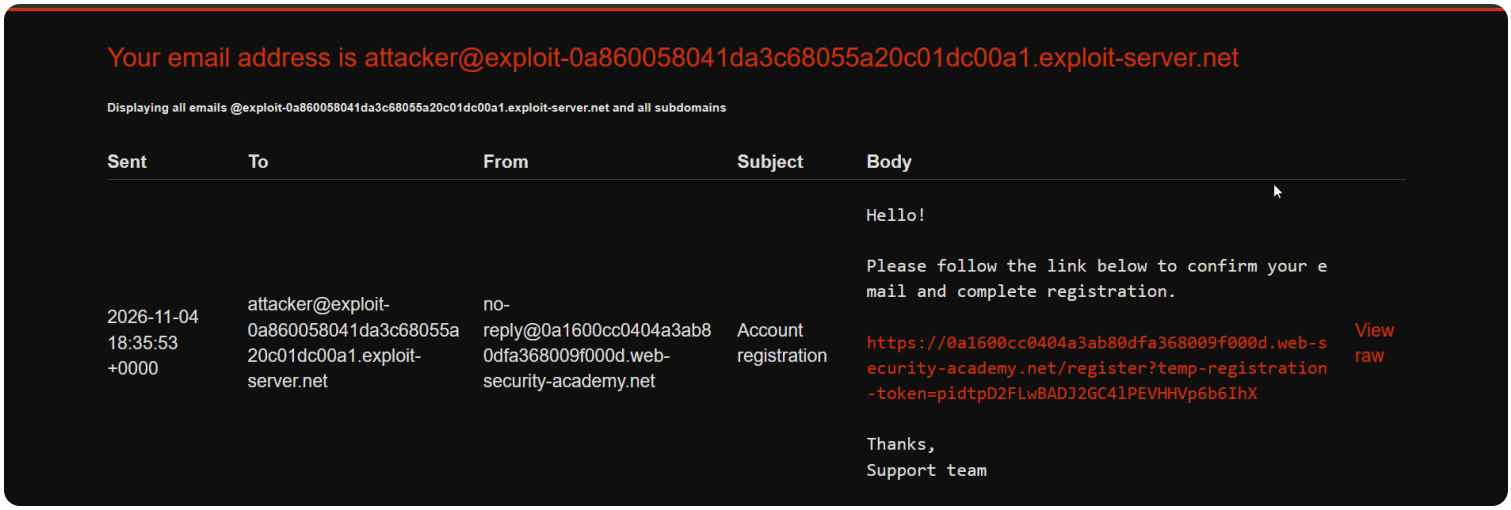
dont forget to remove the [] from the code .

now if u click on register they will send an email verfication to ur own email address as follow:

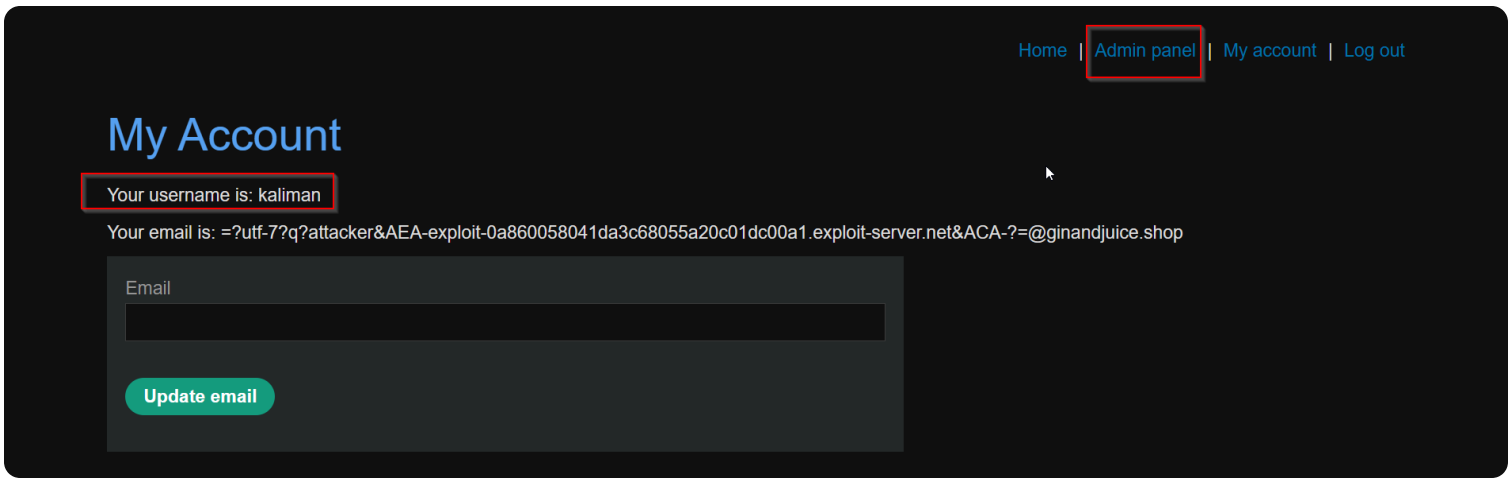




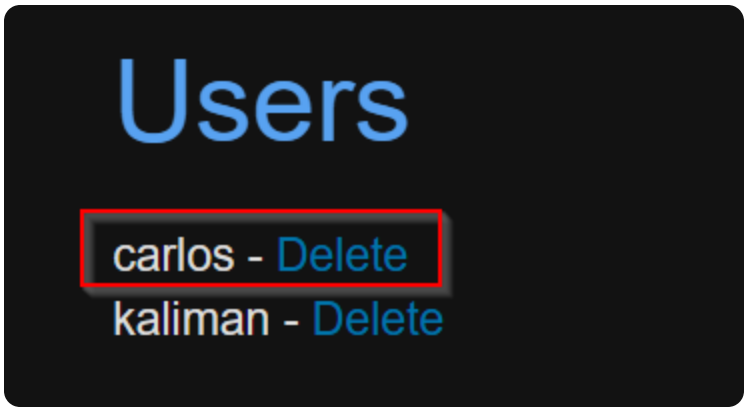




now click at the link they provide and sign in with the account u just created:



go to the admin panel and delete carlos



Here we go u solved the lab :)

kaliman